

OVERVIEW OF THE PROCESSING

Controller(s)

Field	Value
Controller	Operator of civic voting, referendum, election, or TAP deployment
Management units responsible	Product; Election Operations; Legal / Compliance; Data Protection; Security
DPO or similar function	Controller DPO or privacy contact

Processor(s) and Sub-processor(s)

#	Processor	Obligations and Tasks
1	co-mission LLC / Shyware	Provides voting SDK, canonical runtime, optional hosted API, reconciliation
2	Identity verification provider	Verifies eligibility or personhood through Didit, Identus, wallet, or config
3	Cloud infrastructure provider	Hosts API, canonical node, off-chain linkage store, signing infrastructure
4	Mobile app attestation provider	Supports app integrity checks where mobile write-only or hostile-network

Name of the Processing

Internal name: Shyware Civic Voting / Referenda DPIA

Repository evidence: Consumers/POP-U-LIST; Consumers/SEDA_HAQQ; Consumers/taps; shyware/sdk/web/c shyware/embodiments/shyvoting; shyware/services/identity.

DPIA Technical Sheet

Field	Value
Current version	0.1 draft
Reason to conduct DPIA	Civic voting and referenda can reveal or imply political opinions, participation status
Scope	Shyvoting and TAP-style civic deployments using List 1/List 2 separation, IDV or v
Publication	Internal domain DPIA; controller-specific election law and jurisdictional review requ

SYSTEMATIC DESCRIPTION OF THE PROCESSING

High-level Description of the Processing

Processed Personal Data

#	Personal Data Item	Data Type / Data Subject Category	Sp
1	Ballot or submission identifier	Direction-free opaque ballot id derived from nonce	N
2	Vote direction or choice payload	Ballot choice, referendum answer, or TAP preference	P
3	Eligibility / identity hash	IDV, DID, wallet, or public-key-derived identity hash scoped to poll	P
4	Receipt confirmation	User confirmation that registry entry exists	M
5	Tally and audit record	Aggregate counts, Merkle roots, HSM signatures	N
6	Off-chain linkage record	identity hash to ballot id for recovery, withdrawal, or lawful reveal	H

Purposes of the Processing

#	Purpose	Legal Basis Assumption
1	Eligibility-gated anonymous civic participation	Controller-specific public-interest, consent, contr
2	Aggregate tally and public auditability	Public interest / legitimate interests / legal oblig
3	Duplicate-vote prevention and Sybil resistance	Legitimate interests / public interest
4	User receipt verification and possible withdrawal/change	Contract / public interest / legal obligation dep

Nature, Scope and Context The processing supports civic participation, referenda, elections, TAP legislative voting, or governance-like public expression. Even when canonical state does not link identity to vote direction, the processing can reveal participation and can involve political opinion inference. Controller-specific election law, campaign law, platform law, and public-sector rules may apply.

Mainhub Patent Alignment The Mainhub patent architecture supports the claim that valid canonical voting state need not contain a voter–vote-direction join. It does not by itself provide receipt-freeness, coercion resistance, global traffic-analysis resistance, eligibility fairness, or election-law compliance. Off-chain receipt stores, IDV providers, hostile-network exposure, device state, participation evidence, and recovery/change workflows remain high-risk surfaces requiring a standalone voting DPIA.

Authority Partition This is a count-match embodiment. Four structurally separated parties are required:

Authority	Role
Auth (Cognito)	Account layer; always required; gates access
IDV/KYC (Didit)	Verifies voter is a real, eligible person; assess
Eligibility authority (voter registration authority or court officer)	Determines voter eligibility; registered indep
Reconciling authority	Off-chain linkage store + sealer keys

Dual co-authorization enforcement (Claim 2): The validation layer must reject single-signature rescission transactions. Both the eligibility authority and reconciling authority co-signatures are required before any canonical deletion. **VERIFIED (run 26369476939):** *DUAL_COSIG section passes 379/379 — unauthenticated + valid token → 401; authenticated + no token → 400; both co-signatures → 200, countMatch preserved.*

Functional Description

Phase	Operation	Explanation
Eligibility	User completes IDV, DID, wallet, or attestation flow	Eligibility signal becomes score
Ballot cast	Client creates ballot nonce and direction-free ballot id	Ballot choice is stored separately
Canonical write	Runtime commits List 1 vote record and List 2 voter record	Count-match invariant rejects
Close/tally	HSM signs aggregate roots and tally	Public verification without op
Receipt/reconcile	User confirms presence or requests allowed recovery/change	Off-chain linkage must be tight

ANALYSIS OF THE PROCESSING

Lawfulness of the Processing

No single legal basis should be assumed. Political opinion and democratic-participation contexts require jurisdiction-specific counsel review. For public-sector elections, public-interest or legal-obligation bases may apply. For private civic engagement or platform polls, contract, consent, or legitimate interests may be considered, but special-category inference and imbalance must be assessed.

Data Minimisation, Retention Periods, and Data Quality

Data Item	Minimisation Position	Open Review Item
Vote payload	Store only valid choice and required poll metadata	Determine whether payload must
Identity hash	Scope to poll/election to avoid cross-poll tracking	Confirm derivation per identity
Receipt store	Optional; disable for non-recoverable elections	Decide recoverable vs write-only
IDV artifacts	Retain only proof hashes or attestations needed for eligibility	Confirm IDV provider retention
Tally artifacts	Preserve aggregate audit evidence	Define publication and archival

CONSIDERATIONS ON NECESSITY AND PROPORTIONALITY

The architecture is potentially proportionate where eligibility, one-person-one-vote controls, public aggregate audit, and voter privacy are all necessary. Recoverable posture is more intrusive than write-only posture and should be justified by the specific rules of the voting process.

RISK ASSESSMENT AND MANAGEMENT

Risk Assessment and Management

Threats

#	Threat	Materialisation
1	Political preference exposure	Ballot payload linked to person through off-chain store, logs, IDV, or client
2	Participation exposure	Eligibility or receipt confirmation reveals who participated
3	Coercion / vote buying	User is pressured to reveal receipt, device state, or recovery result
4	Eligibility discrimination	IDV or wallet mode excludes eligible participants or creates unfair barriers
5	Tally manipulation	Signing, validator, or state machine compromise corrupts aggregate result

Additional Mitigating Measures

#	Measure
1	Default write-only mode for high-stakes elections unless recovery is legally required
2	Poll-scoped identity derivation with no reusable voter identifier
3	Coercion-resistant receipt policy and no direction-bearing receipt disclosure
4	Accessibility and alternative eligibility process review
5	Independent audit reference or engineering evidence for tally signing, state machine, and count-match invariant

DPIA Audit Findings This DPIA is the audit record for the civic voting and referenda processing pattern. The following findings must be resolved in this DPIA or in a controller-specific version before production.

Audit Area	Required Finding
Patent posture	Write-side canonical state may reduce voter–vote-direction linkage only if the re
Protected linkage / reconcile	Receipt, withdrawal, reveal, or recovery must be disabled or tightly scoped; direc
Provider partitioning	Identify IDV/auth provider, receipt or linkage store, reconciling authority, canon
Participation exposure	Even without a vote-direction join, eligibility, receipt, network access, or device s
Eligibility fairness	IDV, wallet, or DID mode may exclude eligible participants or create discrimina
Residual risk	This DPIA cannot be approved for production until election rules, legal basis, co

Operator Compliance Instructions For the non-code governance residuals identified in this DPIA, the operator is instructed by the **Shyware SDK Compliance Guide** ([patent/mainhub/dpia/source/COM](https://shyware.fyi/legal) published at <https://shyware.fyi/legal>). Key operator obligations:

- **Art. 6 lawfulness basis** — Identify and document the legal basis for each processing purpose before production. Template in Compliance Guide §Operator Obligations.

- **Art. 28 sub-processor DPAs** — Execute signed DPAs with all subprocessors listed in the generated Records of Processing (`node scripts/generate-rop.mjs -config shyconfig.json`).
- **Art. 30 Records of Processing** — Generate from shyconfig using `generate-rop.mjs`; complete all `REQUIRED_OPERATOR_INPUT` fields; maintain under Art. 30(1).
- **Storage limitation (Art. 5(1)(e))** — Add `retention` block to `shyconfig.json`; configure and operationally enforce the `deletion_cron` schedule.
- **Three-authority key independence** — Verify at scoping-identifier creation that eligibility_authority_key $\neq$ reconciling_authority_key $\neq$ auth_key.
- **Quarterly independent audit** — Engage an independent auditor to verify three-authority operational separation before production.

Residual Risk Assessment The residual scores below assume the core Shyware twin-kernel controls are implemented and evidence-linked. The software evidence for the core kernel may be complete while civic/election governance, coercion, participation, accessibility, publication, or controller-rule choices still need to be fixed for this domain. These scores describe residual domain risk after validation; they do not say the kernel tests were missing.

Risk	Additional Measures Applied
Political preference exposure	Canonical separation, receipt policy, provider partitioning
Participation exposure	Scoped eligibility, minimized receipt confirmation, transport/opsec controls
Coercion / vote buying	Write-only mode, no direction-bearing receipt, endpoint restrictions
Eligibility discrimination	Alternative eligibility process and accessibility review
Tally manipulation	Independent audit of state machine, count-match invariant, and signing
Provider consolidation	Authority matrix for IDV, receipt store, reconcile, eligibility, commit, and telem

INVOLVEMENT OF INTERESTED PARTIES

Data subject or representative consultation should be considered for public-facing civic deployments. Election administrators, civil society reviewers, accessibility stakeholders, and DPO/security teams should be involved before production.

CONCLUSION AND DECISION

Draft decision: Separate DPIA required before production deployment. Proceed only after legal basis, election rules, identity mode, coercion posture, retention, publication, and recovery mode are fixed.

Regulatory and Deployment Context Annexes

Annex A — Deployment Context Variants

Deployment context	Elevated risk	Regulatory trigger	Additional requirement
Civic referenda (non-binding)	Political opinions (Art. 9); participation exposure	Art. 9(1) GDPR	Art. 9(2)(a) explicit consent; identity-mode review; transport-opsec controls documented
Binding national elections	Voter anonymity legally mandated; tally must be independently verifiable; coercion-resistance may be required by election law	National election legislation; Council of Europe Recommendation CM/Rec(2017)5	Independent audit of state machine and HSM attestation; election authority approval before deployment; write-only posture assessment per jurisdiction
Hostile-regime / coercion-resistant (SEDA_HAQQ posture)	Participation as evidence of dissent; coercion under device seizure	No specific regulation — threat-model driven	Coercion-resistant posture mandatory; write-only mode; APK distribution outside app stores; ZK nullifier tier for participation inference resistance
Corporate / DAO governance	Wallet-weighted governance; plutocratic concentration risk; SEC scrutiny of token-voting if security	US SEC (DAO governance token may be a security); EU MiCA Art. 79	Legal opinion on token classification; governance-weighting transparency; quorum and delegation rules documented
Employee / union ballot	Employment law; union ballot secrecy requirements (UK TULRCA, DE BetrVG)	UK Trade Union and Labour Relations Act; German Betriebsverfassungsgesetz	Works council consultation; union-specific ballot secrecy rules; retention limited to dispute window

Annex B — Art. 9 Political Opinions Analysis

Voting and governance data is Art. 9(1) special-category data (political opinions) in most EU member states. The legal basis must be Art. 9(2)(a) explicit consent, or Art. 9(2)(g) substantial public interest with appropriate safeguards (for official elections). The structural anonymity guarantee reduces the risk that any individual's vote direction is disclosed from canonical state, but does not eliminate the Art. 9 classification because: (a) participation itself may reveal political engagement; (b) the identity hash in List 2 confirms the subject voted (participation

record). Operators must: document the Art. 9(2) basis; implement the minimum eligibility-data model; confirm that participation records are not shared without data subject instruction.

Annex C — Jurisdiction-Specific Election Law

Jurisdiction	Key requirements	Shyware structural coverage
EU member states	GDPR Art. 9 political opinions; eIDAS for identity where applicable; national election law varies significantly	Structural anonymity + HSM attestation addresses core ballot-secrecy requirement; eligibility and identity-mode configuration operator-specific
United States	No federal online-voting law; HAVA (Help America Vote Act) for federal elections; state-level rules vary; export controls on cryptographic software (EAR/ITAR)	HAVA does not permit internet voting for federal elections without specific state authorization; shyvoting suitable for referenda, surveys, governance; not approved for HAVA-covered elections without state election authority waiver
United Kingdom	Electoral Administration Act 2006; Electoral Commission guidance on internet voting pilots	Internet voting permitted only under Electoral Commission pilot authorization; structural audit trail supports pilot evidence requirements
International / hostile-regime	No applicable regulation by definition; OSCE/ODIHR election observation standards apply to credibility	Coercion-resistant posture + ZK nullifier tier provides evidence for OSCE structural-anonymity criterion